THE ANATOMY OF IOS SECURITY IN 2025

PRESENTED BY BRUNO SENA



WHOAMI

NAME: BRUNO SENA

NATIONALITY: BRAZILIAN

COMPANY: THALLIUM SECURITY

DEGREE: COMPUTER SCIENCE

EXPERTISE: OFFENSIVE SECURITY & MOBILE SECURITY

APPLE BUG BOUNTY

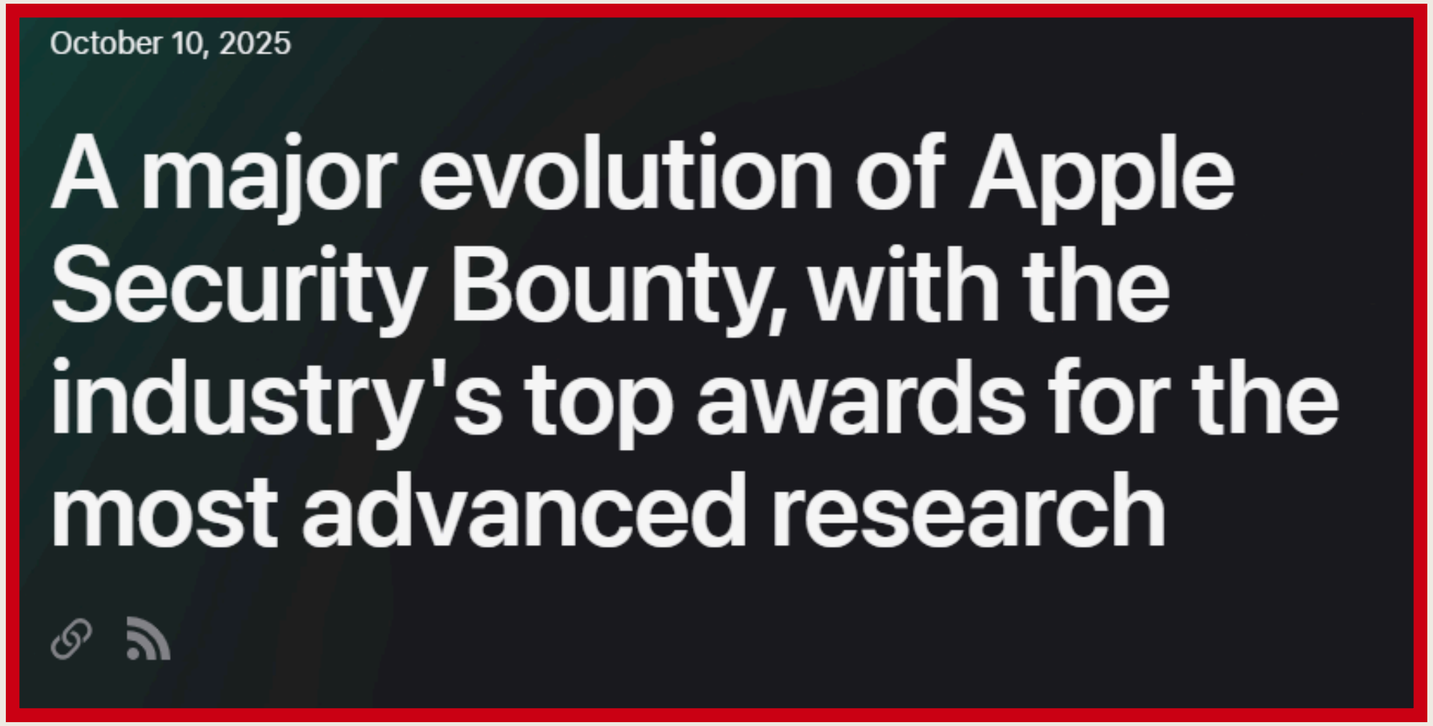
MUDANÇAS A PARTIR DE NOVEMBRO DE **2025**

RECOMPENSA MÁXIMA DOBRADA PARA **2 MILHÕES** DE DÓLARES

INTRODUÇÃO DAS **TARGET FLAGS**

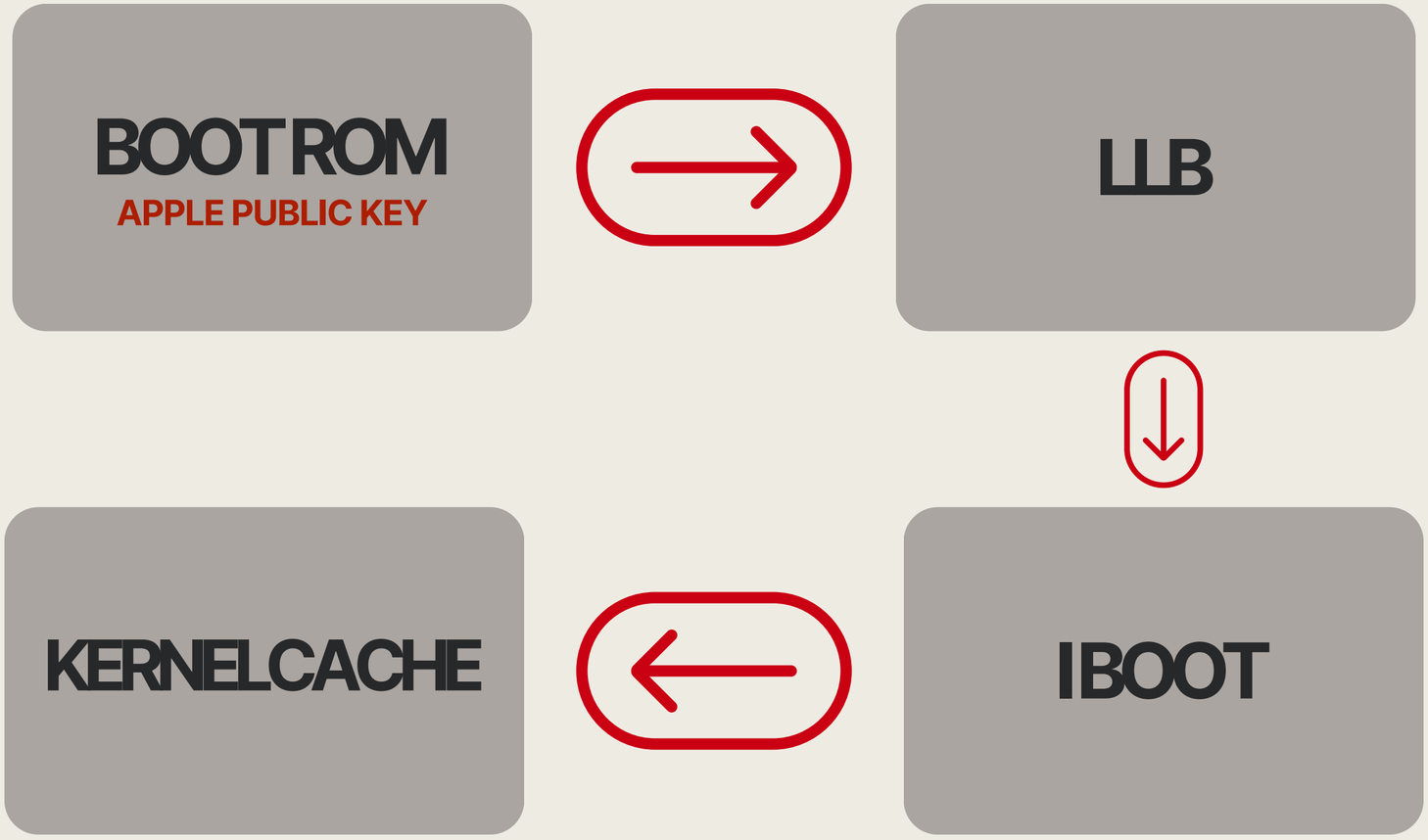
NOVAS CATEGORIAS DE VULNERABILIDADES

INCENTIVO PARA **NOVOS PESQUISADORES**



HTTPS://SECURITY.APPLE.COM/BLOG/APPLE-SECURITY-BOUNTY-EVOLVED/

SECURE BOOT CHAIN

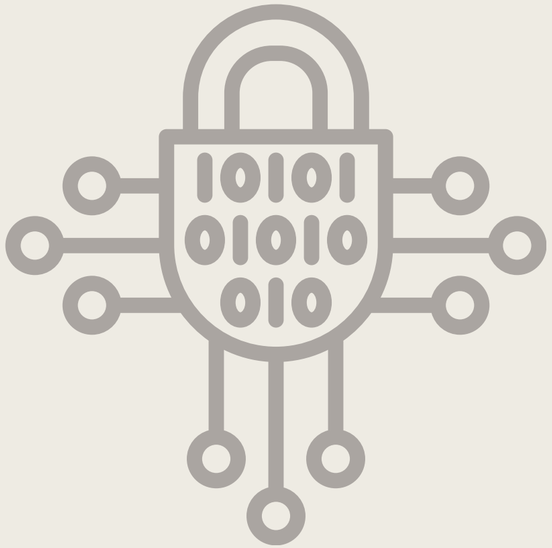


SECURE ENCLAVE PROCESSOR (SEP)

PROCESSADOR **INDEPENDENTE** RESPONSÁVEL POR OPERAÇÕES **CRIPTOGRÁFICAS**

PRIMEIRA IMPLEMENTAÇÃO EM **2013**, NO IPHONE **5S**. USADO PARA O PROCESSAMENTO DO **TOUCH ID**

CPU E MEMÓRIA **PRÓPIOS** E **ISOLADOS**



O **ISOLAMENTO** DO RESTANTE DOS COMPONENTES **DIFICULTA** O COMPROMETIMENTO DAS FUNÇÕES CRIPTOGRÁFICAS

AS CHAVES DE CRIPTOGRAFIA **NUNCA DEIXAM** O AMBIENTE DO SECURE ENCLAVE

2025: SEP AINDA MAIS INTEGRADO, COM SUPORTE A CHAVES CRIPTOGRÁFICAS **MAIS COMPLEXAS** E SECURE BOOT **APRIMORADO**

POINTER AUTHENTICATION (PAC)

IMPLEMENTADO PELA PRIMEIRA VEZ EM **2018**, NOS CHIPS **A12 BIONIC**

IMPLEMENTAÇÃO A NÍVEL DE **HARDWARE**

ASSINA PONTEIROS CRÍTICOS USANDO **CHAVES** SECRETAS DO PROCESSADOR

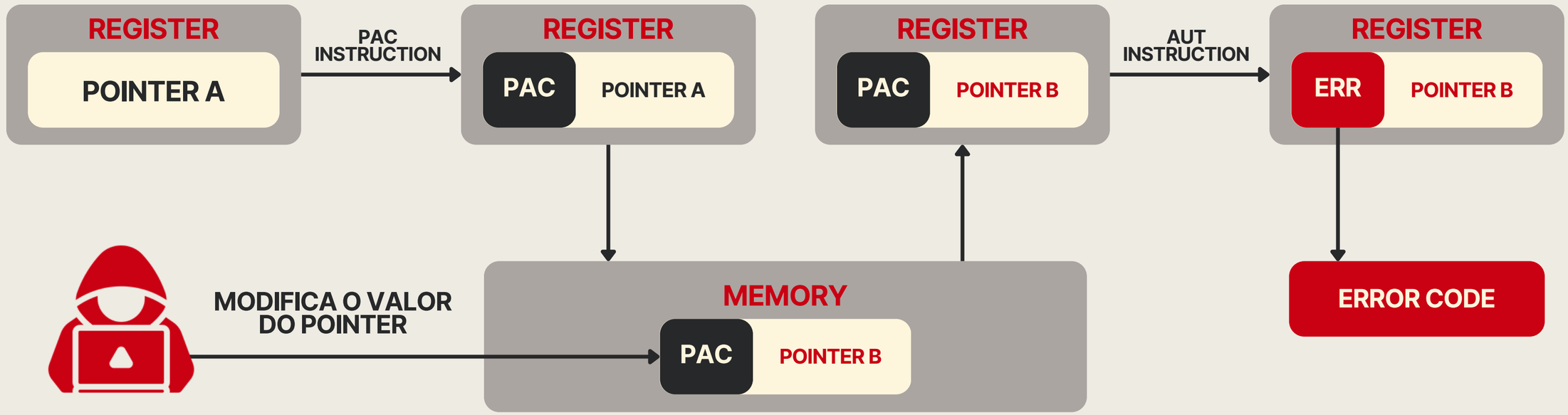
DETECTA **CORRUPÇÃO** E **MANIPULAÇÃO** DE MEMÓRIA

PROTEGE CONTRA ATAQUES **ROP** E **USE-AFTER-FREE**

POINTER AUTHENTICATION (PAC)

PAC INSTRUCTION → **APLICA** A ASSINATURA

AUT INSTRUCTION → **VERIFICA** A ASSINATURA



SANDBOXING & ENTITLEMENTS

SANDBOXING

ISOLAMENTO DE APPS. CADA APLIÇÃO É EXECUTADA EM UM CONTEXTO **PARTICULAR** E **ISOLADO**

/VAR/MOBILE/CONTAINERS/DATA /APPLICATION/**<UUID>**

SEM ACESSO DIRETO A ARQUIVOS E FUNÇÕES DE OUTROS APPS.

ENTITLEMENTS

ATRIBUTOS **DECLARATIVOS** DE UM APP QUE CONCEDEM **PERMISSÕES** ALÉM DO SANDBOX PADRÃO

CONTROLAM ACESSO A **APIS** E RECURSOS DO SISTEMA, COMO ICLOUD, APPLE PLAY, PUSH NOTIFICATIONS E ETC

DEFINIDOS NO ARQUIVO **.ENTITLEMENTS (PLIST)**

SANDBOXING & ENTITLEMENTS

```xml
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN" "http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
    <key>com.apple.developer.icloud-container-identifiers</key>
    <array>
        <string>iCloud.com.exemplo.meuapp</string>
    </array>
</dict>
</plist>
```

CODE SIGNING & APP REVIEW

CODE SIGNING

ASSINATURA DIGITAL DE UM APLICATIVO COM UM CERTIFICADO APPLE

VALIDADO EM RUNTIME PELO KERNEL, ATRAVÉS DO **AMFI** (APPLE MOBILE FILE INTEGRITY)

IDENTIFICA O DESENVOLVEDOR AUTORIZADO E GARANTE A **INTEGRIDADE** DO APP

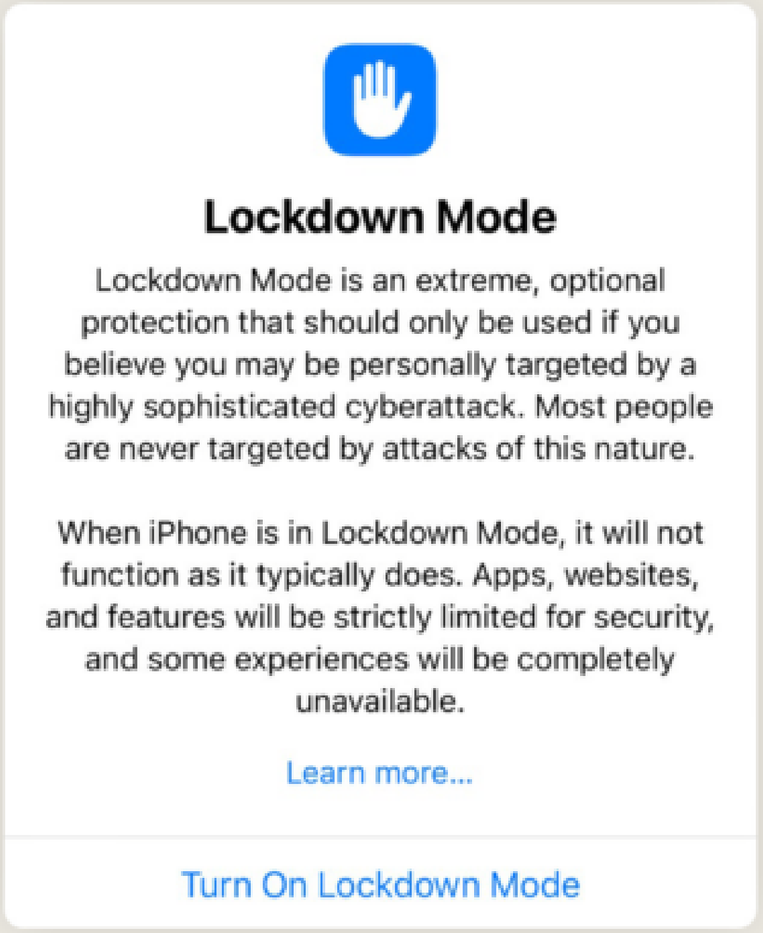
APP REVIEW

APPLE REALIZA UMA **VERIFICAÇÃO AUTOMÁTICA** NO APP ANTES DA PUBLICAÇÃO

VERIFICAÇÃO DE USO DE **APIS PRIVADAS** OU DE FRAMEWORKS QUE QUEBREM AS REGRAS DE SANDBOX.

VERIFICA O USO DE BOAS PRÁTICAS DE **CRIPTOGRAFIA** E **ARMAZANAMENTO** LOCAL

LOCKDOWN MODE



CAMADA EXTREMA DE PROTEÇÃO CONTRA ATAQUES SOFISTICADOS

FOI INTRODUZIDO PELA APPLE NO IOS 16, EM 2022

VOLTADO A USUÁRIOS DE ALTO RISCO, COMO JORNALISTAS, ATIVISTAS, POLÍTICOS E GRANDES EMPRESÁRIOS

REDUZ DRASTICAMENTE A SUPERFÍCIE DE ATAQUE DO IOS AO DESABILITAR UMA SÉRIE DE FUNCIONALIDADES POTENCIALMENTE EXPLORÁVEIS

RESTRIÇÕES NO IMESSAGE, SAFARI, SERVIÇOS DE REDE E OUTROS

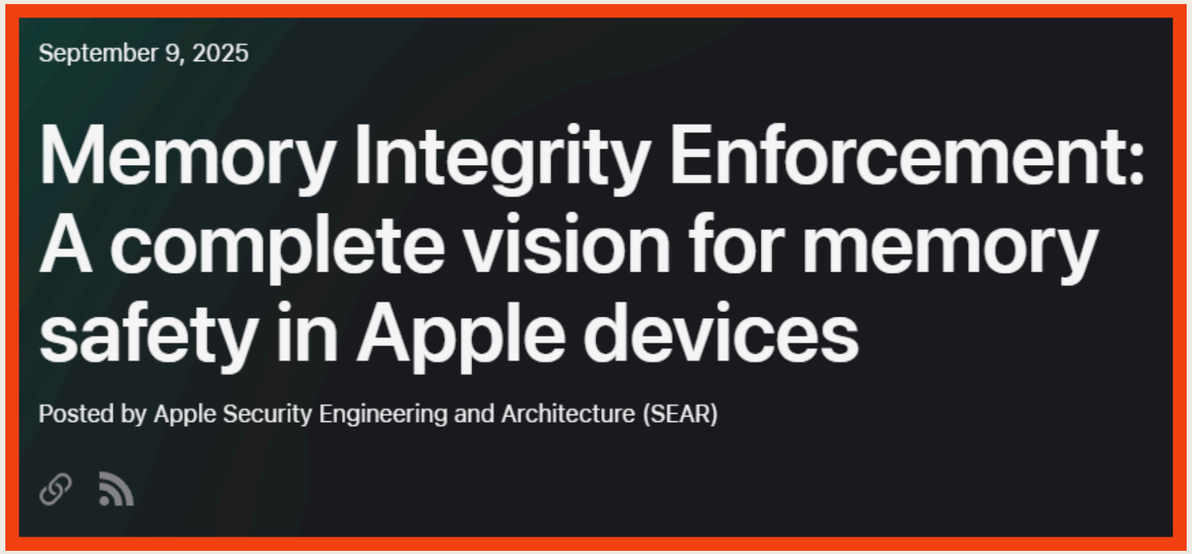
MEMORY INTEGRITY ENFORCEMENT (MIE)

NOVO MECANISMO DE **PROTEÇÃO DE MEMÓRIA** SEMPRE ATIVO (ALWAYS-ON)

IMPLEMENTADO EM 2025 NOS MODELOS **IPHONE 17** E **IPHONE AIR**

A ATUALIZAÇÃO DE SEGURANÇA DE MEMÓRIA **MAIS SIGNIFICATIVA DA HISTÓRIA** DOS SISTEMAS OPERACIONAIS VOLTADOS AO CONSUMIDOR

FORTE **INTEGRAÇÃO** ENTRE OS CHIPS A19 E O IOS 26



MEMORY INTEGRITY ENFORCEMENT (MIE)

BASEADO NA TECNOLOGIA **MEMORY TAGGING EXTENSION (MTE)**, PUBLICADA PELA ARM EM 2019

O MTE UTILIZA **TAGS SECRETAS** EM CADA ENDEREÇO DE MEMÓRIA PARA DETECTAR E PREVENIR CORRUPÇÃO EM TEMPO REAL

A APPLE IDENTIFICOU **LIMITAÇÕES NO MTE ORIGINAL** E COLABOROU COM A ARM PARA CRIAR O **EMTE** EM 2022, APRIMORANDO SIGNIFICATIVAMENTE A SEGURANÇA DO MECANISMO

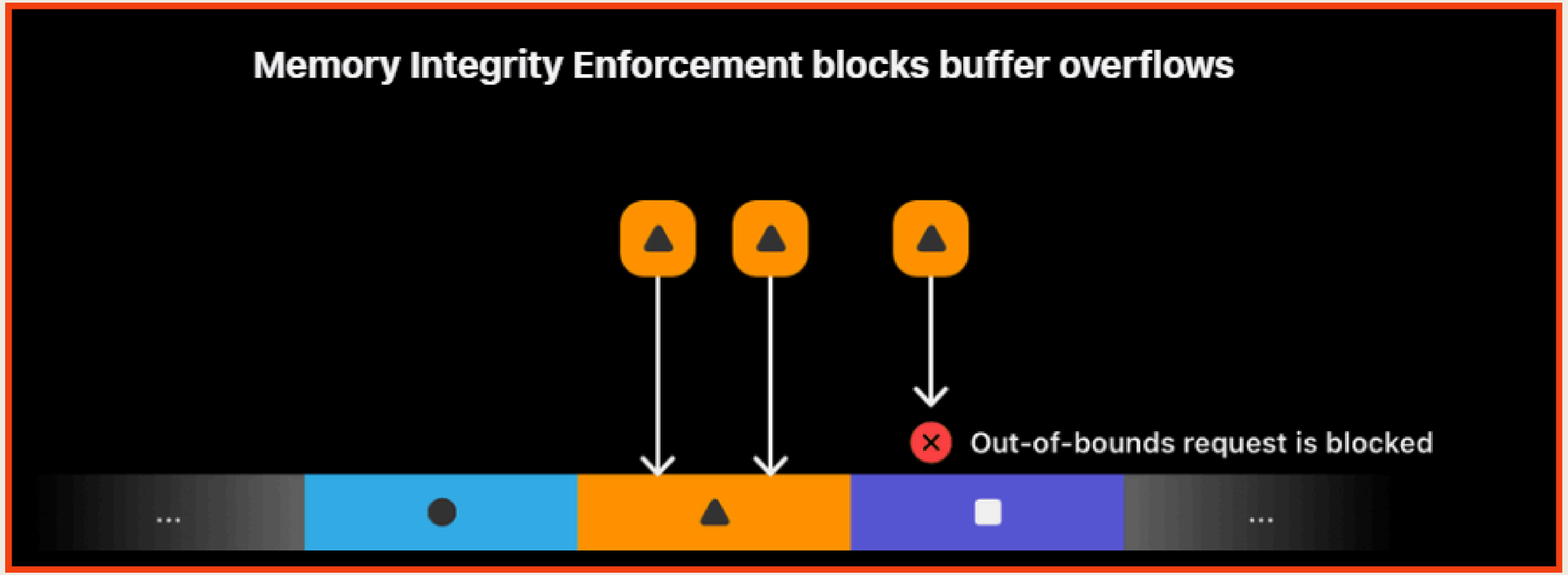
MEMORY INTEGRITY ENFORCEMENT (MIE)

EMTE EM MODO SÍNCRONO

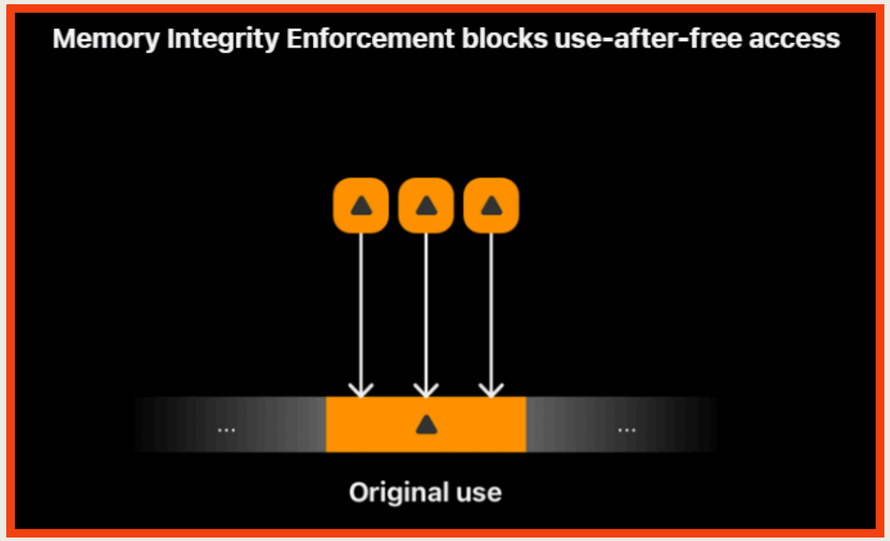
ALOCADORES DE MEMÓRIA SEGUROS

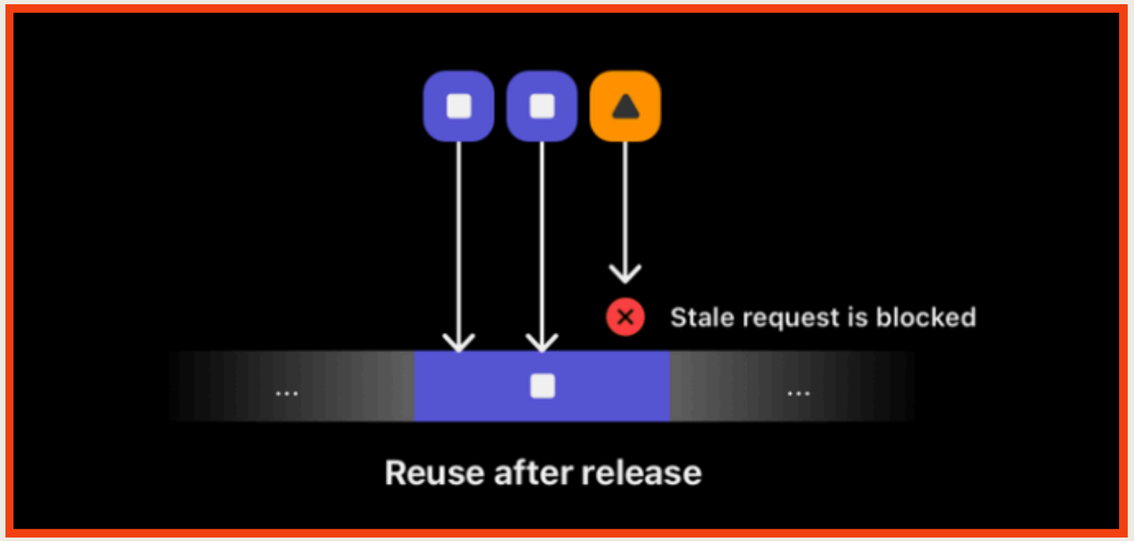
APLICAÇÃO (ENFORCEMENT) DA CONFIDENCIALIDADE DAS TAGS

MEMORY INTEGRITY ENFORCEMENT (MIE)



MEMORY INTEGRITY ENFORCEMENT (MIE)





XNU SECURITY

ATUALIZAÇÕES QUE TRANSFORMAM O KERNEL XNU MONOLÍTICO EM UM SISTEMA MAIS COMPARTIMENTALIZADO

SECURE PAGE TABLE MONITOR (SPTM)

TRUSTED EXECUTION MONITOR (TXM)

EXCLAVES

SECURE PAGE TABLE MONITOR (SPTM)

A ÚNICA AUTORIDADE CAPAZ DE **MANIPULAR PAGE TABLES** E REALIZAR RECLASSIFICAÇÃO DE FRAMES

INTRODUZ DOMÍNIOS DE CONFIANÇA **(DOMÍNIOS SPTM)**, QUE FUNCIONAM COMO FRONTEIRAS DE PRIVILÉGIO PARA **ISOLAR** DIFERENTES FUNCIONALIDADES

MESMO QUE O **KERNEL XNU** SEJA COMPROMETIDO, UM ATACANTE NÃO CONSEGUE MANIPULAR AS REGRAS DE MAPEAMENTO

TRUSTED EXECUTION MONITOR (TXM)

O **TXM** É UM COMPONENTE DE SEGURANÇA QUE OPERA EM SEU PRÓPRIO DOMÍNIO SPTM ISOLADO **(TXM_DOMAIN)**

SUA PRINCIPAL FUNÇÃO É IMPOR POLÍTICAS DO SISTEMA QUE CONTROLAM A **INTERPRETAÇÃO** E A **EXECUÇÃO** DE CÓDIGO

ENCAPSULA E **ISOLA** SERVIÇOS SENSÍVEIS, COMO ASSINATURA DE CÓDIGO E VERIFICAÇÃO DE ENTITLEMENTS

EXCLAVES

CLUSTERS ISOLADOS DE RECURSOS SENSÍVEIS (SENSORES, SIL, ANE) DENTRO DO **SK_DOMAIN (SECURE KERNEL DOMAIN)**

SIL → SECURE INDICATOR LIGHT
ANE → APPLE NEURAL ENGINE

REFERÊNCIAS

HTTPS://SECURITY.APPLE.COM/BLOG/APPLE-SECURITY-BOUNTY-EVOLVED/

HTTPS://SECURITY.APPLE.COM/BLOG/MEMORY-INTEGRITY-ENFORCEMENT/

HTTPS://ARXIV.ORG/PDF/2510.09272

HTTPS://SUPPORT.APPLE.COM/GUIDE/SECURITY/OPERATING-SYSTEM-INTEGRITY-SEC8B776536B/WEB

HTTPS://WWW.BLACKHAT.COM/DOCS/US-16/MATERIALS/US-16-MANDT-DEMYSTIFYING-THE-SECURE-ENCLAVE-PROCESSOR.PDF

MUITO OBRIGADO!

